信息安全研究 Journal of Information Security Research 第9卷 第5期 2023年5月 Vol.9 No.5 May 2023
DOI:10.12379/j.issn.2096-1057.2023.05.02

SQL 注入攻击检测与防御技术研究综述

王安琪[1] 杨 蓓[2] 张建辉[1] 王瑞民[2]
[1](郑州大学网络空间安全学院 郑州 450002)
[2](郑州大学计算机与人工智能学院 郑州 450002)
(anqiwang2333@163.com)

A Survey of SQL Injection Attack Detection and Defense Technology

Wang Anqi[1], Yang Bei[2], Zhang Jianhui[1], and Wang Ruimin[2]
[1](*School of Cyber Science and Engineering, Zhengzhou University, Zhengzhou* 450002)
[2](*School of Computers and Artificial Intelligence, Zhengzhou University, Zhengzhou* 450002)

Abstract In the era of "Internet+", data is the most valuable resource of the Internet. Attackers often use SQL injection attacks to destroy the database in order to obtain important data information in the database. The threat to database security is becoming more and more serious. At present, the research on SQL injection attacks mostly focuses on traditional SQL injection attacks, but lacks the cognition of new advanced SQL injection technology with stronger concealment and higher risk, and the research on related detection and defense technology. In response to this phenomenon, this paper analyzes and evaluates traditional and advanced SQL injection attack technologies and their technical characteristics based on the classification of SQL injection technologies; summarizes existing detection and defense technologies, and evaluates the advantages and disadvantages of these methods for defense effectiveness; finally The problems existing in the current research field are sorted out, and suggestions for future research directions are put forward.

Key words SQL injection attack; detection and defense; traditional and advanced; Web security; database security

摘 要 在互联网+时代,数据是互联网最宝贵的资源,攻击者为获取数据库中的重要数据信息常采用 SQL 注入攻击方式对数据库进行破坏,数据库安全面临的威胁日益严峻.目前有关 SQL 注入攻击的研究多集中在传统 SQL 注入攻击上,而缺乏对于隐蔽性更强、危险性更高的新型高级 SQL 注入技术的认知及相关检测与防御技术的研究.针对这一现象,从 SQL 注入技术分类出发对传统和高级 SQL 注入攻击技术及其技术特点进行分析评价;对现有检测与防御技术归纳总结,并对这些方

收稿日期:2022-07-04
基金项目:国家自然科学基金面上项目(62176264)
通信作者:张建辉(ndsczjh@163.com)
引用格式:王安琪,杨蓓,张建辉,等. SQL 注入攻击检测与防御技术研究综述[J]. 信息安全研究,2023,9(5):412-422

法的优缺点和防御有效性进行评价;最后针对当前研究领域存在的问题进行梳理,为今后的研究方向给出建议.

关键词 SQL 注入攻击;检测与防御;传统与高级;Web 安全;数据库安全

中图法分类号 TP309.2

Web 应用程序作为用户和数据库交互的桥梁,操作便捷不受时空和地域的限制,通过结构化查询语句(structured query language, SQL)对网络服务数据进行访问.数据共享在给人们带来便利的同时也必然会伴随着数据库安全问题[1].应用程序作为检索或插入数据库中的数据接口成为 SQL 注入攻击的攻击对象.

SQL 注入攻击允许攻击者通过构造特殊的 SQL 语句绕过身份验证,进而提权、修改或删除重要数据,甚至使数据库停止服务,实现对数据库的绝对访问.SQL 注入攻击具有原理简单、使用方便、攻击获益大、攻击门槛低等特性,使得其从发现至今从未断绝.根据开放式 Web 应用程序安全项目组织 OWASP(Open Web Application Security Project)[2]历年发布的 Web 安全威胁评估报告显示,SQL 注入漏洞一直名列前茅.在 CWE Top25 Most Dangerous Software Error[3]列表中,SQL 注入攻击在 2020 年度和 2021 年度稳居第 6.由此可见 SQL 注入仍是当前应用程序面临的主要威胁之一.

随着新型技术的快速发展,SQL 注入攻击的各种绕过方式也在不断升级,灵活多变的注入方式将使检测难度进一步升级.当前的大量研究多是针对传统 SQL 注入攻击,然而新型高级 SQL 注入攻击才是最隐蔽、最危险的,却鲜有人研究.针对此,本文从 SQL 注入技术分类出发对传统和高级 SQL 注入攻击技术及其技术特点进行分析评价;对现有检测与防御技术归纳总结,并对其优缺点和防御有效性进行评价;最后针对当前研究领域存在的问题进行梳理,为今后的研究方向给出建议.

1 SQL 注入攻击研究

1.1 SQL 注入攻击原理

SQL 注入产生的实质是因为恶意代码被伪装成正常的输入数据,与正常请求拼接在一起,提交到服务器的数据库解析执行.SQL 注入攻击流程如图 1 所示:

图 1 SQL 注入攻击流程

大多数 Web 应用编程语言均提供了可编程的方法与数据库连接并与之交互.如果 Web 应用程序开发人员在将用户输入数据传递给 SQL 查询之前没有对其进行合法性验证,就会存在 SQL 注入的风险.由于漏洞的存在攻击者能够利用该漏洞控制 SQL 查询的输入,拼接攻击载荷,并且能够通过一定的逃逸技术绕过检查将该输入数据解析为可执行代码[4],达到 SQL 注入的目的.

1.2 SQL 注入攻击特性

SQL 注入攻击形式多样,复杂多变,不同的攻击类型需要的先决条件不同,从而产生的攻击效果也不同.SQL 注入攻击的攻击特性如下:

1) 直接显示.少数攻击可以使页面直接显示从数据库中获取的结果,有些攻击则需要通过页面返回信息进行推断.

2) 错误推理.此类攻击需要目标网站显示错误信息或错误页面,攻击者通过这些错误信息推断出数据库相关信息.

3) 数据窃取.数据库中的敏感信息是攻击者的主要目标之一,可通过 SQL 注入攻击入侵到数

据库内部，获取数据库中存储的密码、身份证号、信用卡账户等信息.

4）破坏可用性.攻击者可以对数据修改或删除，甚至删除整张表或者整个数据库，采用系统命令使数据库停止服务等，破坏数据完整性和数据库可用性.

5）绕过身份验证.用户发出请求时，Web 应用会对用户身份进行验证，攻击者可通过一定的 SQL 注入攻击绕过该环节.

2 SQL 注入攻击分类

2.1 传统 SQL 注入攻击

通过对多篇论文[5-6]的研究分析，可以将传统注入攻击分为以下类型：

1）重言式(tautologies).通过构造查询条件使注入语句的判定结果恒真，从而绕过原语句中的验证.

2）堆叠查询(piggy-backed query).使用查询分隔符(如“;”)在原始查询后附加额外语句，达到破坏数据库的目的.

3）逻辑错误查询(logically incorrect).通过分析回显的报错信息可获得系统内部的一些关键信息.

4）联合查询(union query).通过“UNION”关键字连接 2 条甚至多条 SQL 查询语句，然后把查询到的结果进行拼接，从而获取敏感数据.

5）存储过程(stored procedure).存储过程是数据库中的一个重要对象，其中包含参数，在参数传递过程中可能遭受 SQL 注入攻击.

6）盲注(inference).对比观察页面响应判断注入语句的执行是否成功，可分为布尔盲注和时间盲注.

7）编码替换(alternate encodings).该攻击不属于某种特定的攻击类型，它可以与其他攻击类型联合使用，旨在避开后端的防御和过滤机制.

2.2 高级 SQL 注入攻击

2.2.1 利用 Fast Flux 进行 SQL 注入攻击

攻击者通过网络钓鱼这种社会工程学的方式，利用第三方身份欺诈性地从用户那里获取数据库中敏感信息.一般情况下通过跟踪公共域名服务器(DNS)或 IP 地址就可以容易检测到传统的网络钓鱼主机.因此，攻击者为了保护其犯罪资产采用 Fast Flux 技术构建僵尸网络，将恶意站点隐藏在不断变化的受控主机网络后，逃避追踪.Fast Flux 技术可以不断改变域名和 IP 地址映射关系.任何一个域都只在很有限的时间内活跃，这样，当相关域所关联的恶意活动被发现后，将能以最快速度用新的域来接手，确保网络服务不受影响.这样，整个僵尸网络将能获得额外的一层冗余和生存能力.运用该方法可以让基于 IP 封锁清单的方法在防御攻击时失效.图 2 所示为 Fast Flux 攻击方式.利用 Fast Flux 进行大规模 SQL 注入攻击方式很难被预测和防御，对该攻击进行防御和检测的研究也很少.

2.2.2 利用跨域策略进行 SQL 注入攻击

当今网络中大多数网站都使用 Adobe Flash，

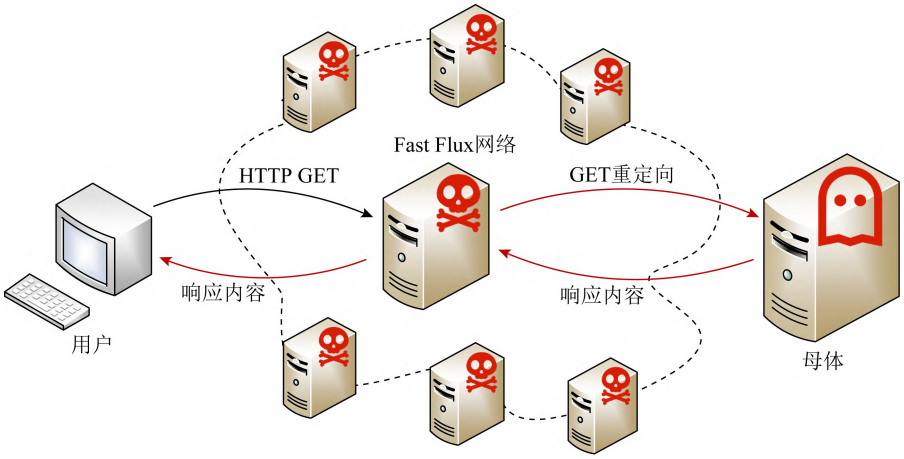

图 2 Fast Flux 攻击方式

Adobe Reader 和 Microsoft Silver Light 等来增强和增加网站的用户交互性[7].它们都是利用跨域策略进行设计,以实现多操作系统上的无缝运行.跨域是指需要访问其他域服务器获取所需资源,跨域策略通过设置 XML 文档文件制定 Web 客户端跨域处理数据的权限.但如果在编码时不严谨或者错误地使用跨域策略就会导致漏洞的出现,在网站使用过程中很容易被攻击者利用,受到 SQL 注入以及其他类型的攻击.不严谨的跨域策略编码示例如下:

```
〈?xml version="1.0"?〉
〈!DOCTYPE cross-domain-policy SYSTEM
"http://www.evil.com/files/ xml/dtds/
cross-domain-policy.dtd"〉
〈cross-domain-policy〉
  〈allow-access-from domain="*.evil.com"/〉
  〈allow-access-from domain="* "/〉
〈/cross-domain-policy〉
```

通配符"*"单独使用表示允许所有请求者进行访问,不加限制的策略会给网站带来严重的安全威胁,为了网站安全应尽量避免使用.

2.2.3 SQLI+DDoS 混合攻击

SQL 为了方便用户获得输出,允许用户创建极其复杂的查询,这就为数据库带来安全隐患,也为 SQLI+DDoS 混合攻击提供了便利[8].如果一个网站存在 SQL 注入攻击漏洞,就可以利用 compress(),encode(),join()等数据库命令去构造 1 条足够复杂的 SQL 语句,拼接在正常的请求之后在数据库中执行,以此耗尽数据库服务器资源.

假设某网站存在 SQL 注入攻击漏洞,且可以使用以下语句成功注入:

http://www.example.com/login.php?id=1 union select 1,2,3,4--

假设第 2 个字段可以用来回显,将构造的复杂攻击语句拼接在第 2 个字段处,构造出以下可以进行 DDoS 攻击的 SQL 注入语句:

http://www.example.com/login.php?id=1 union select 1,(select pd from (select de-code(encode(convert(compress(post) using latin1),des_encrypt(concat(post,post,post,post),6)),des_encrypt(sha1(concat(post,post,post,post)),7)) as pd from user)a),3,4--

2.2.4 SQLI+DNS 劫持混合攻击

攻击者可以将 SQL 查询嵌入 DNS(domain name server)请求中,经过有注入漏洞的 Web 服务器解析后提取数据库中的有效数据[9].攻击者只需要额外搭建一个 NS 服务器,在请求发出时将攻击语句放在自己域名的 2 级或者 3 级域名上,数据库就会把查询结果和域名拼接起来进行 DNS 查询,攻击者只要获取 DNS 解析日志就能够获取注入语句查询结果.

SQLI+DNS 劫持混合攻击方式如图 3 所示.在该过程中攻击者构造的攻击载荷为:

provoke_dns((SELECT password FROM account WHERE name='admin').attacker.com)

SELECT 语句用于获取攻击者想要的数据信息,并在查询语句之后拼接上一个攻击者可以控制的域名(.attacker.com),该语句在经过数据库时会被执行查询操作,并将 admin 的密码拼接在被控制域名前.

2.2.5 SQLI+XSS 混合攻击

XSS(cross site script)攻击原理是在网站中注入恶意的 JavaScript,VBScript,HTML 代码,这段注入代码在用户浏览该网站时触发自动执行,获取私密网页内容,获取用户 cookie、会话劫持、用户重定向等,从而达到攻击的目的[8].XSS 攻击与 SQL 注入攻击都属于注入攻击,但又有所不同,SQL 注入攻击中以服务器端结构化查询语句作为用户输入,从而达到对数据库中数据查询、修改、删除的目的.而在 XSS 攻击中使用客户端语言进行恶意脚本注入,实现对用户浏览器的控制,获取用户的一些信息.如果攻击者在客户端语言中拼接尝试连接网站数据库的攻击载荷,一旦连接成功,攻击者将可以通过客户端语言访问数据库.

2.2.6 二阶 SQL 注入攻击

2.1 节中介绍的传统的 SQL 注入攻击都属于一阶 SQL 注入技术,把攻击载荷动态构造到 SQL 的正常请求中并被数据库解析执行,网页会对该注入语句执行成功与否作出立即响应[10-11].二阶 SQL 注入攻击是将 SQL 注入过程分为 2 个阶段,其中的攻击载荷由于 Web 应用程序的条件限制无法立即执行,需要首先由存储阶段通过相关命令如 INSERT 把攻击载荷存入数据库,之后再由触发阶段通过相关请求如 UPDATE 和 SELECT

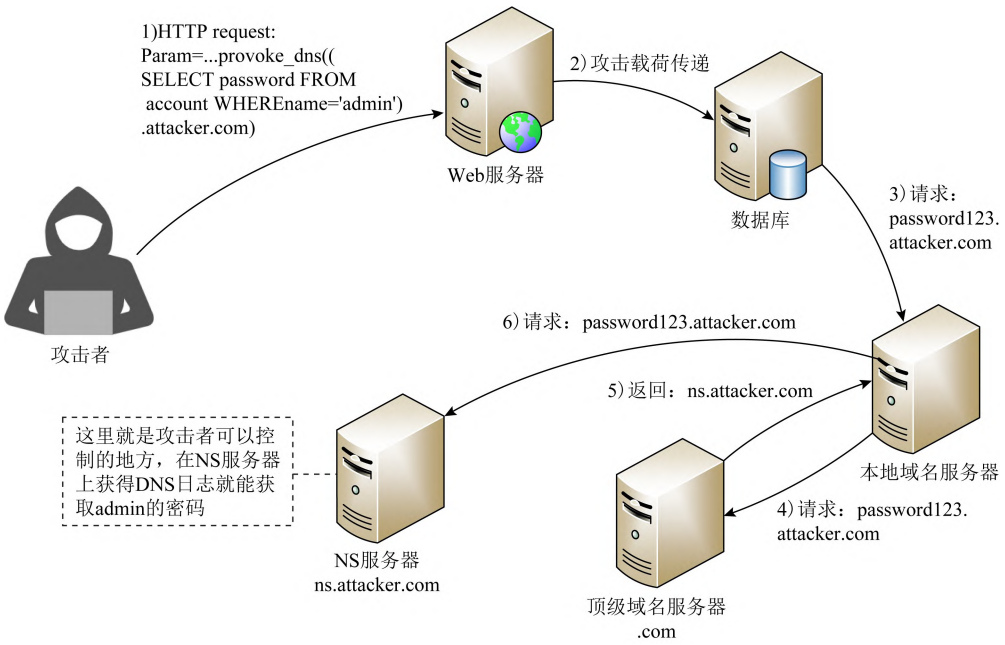

图 3　SQLI+DNS 劫持混合攻击方式

命令检索先前存入数据库中的攻击载荷，实现语句拼接构造 SQL 注入在 Web 服务器中解析执行.二阶 SQL 注入攻击流程如图 4 所示.其中步骤 1)～4)属于存储阶段，步骤 5)～17)属于触发阶段.这 2 个阶段通常在应用程序的不同位置合作完成.预编译可以保证 SQL 语句语义的不变性，可实现对一阶 SQL 注入攻击的有效防御.但预编译的方法也存在局限性，被参数化查询存储到数据库中的数据有可能是攻击者精心构造过的语句.当用户在 Web 应用程序中使用其他功能时被触发，从而产生二阶 SQL 注入攻击.不难发现二阶 SQL 注入攻击存储阶段的攻击载荷可以是一阶 SQL 注入攻击任何一种攻击类型，相较于一阶更加隐蔽，更加难以防御.

2.3　SQL 注入攻击评价分析

下面将对 2.1 和 2.2 节介绍的传统 SQL 注入攻击和高级 SQL 注入攻击技术(如表 1 所示)进行评价.表 1 为各攻击技术及对应标号，具体分析比较结果如表 2 所示.

通过表 1 和表 2 可知，传统 SQL 注入攻击采用带内通信方式进行，攻击过程中时间延迟低，攻击门槛低，操作简单，很容易达到攻击目的，是攻

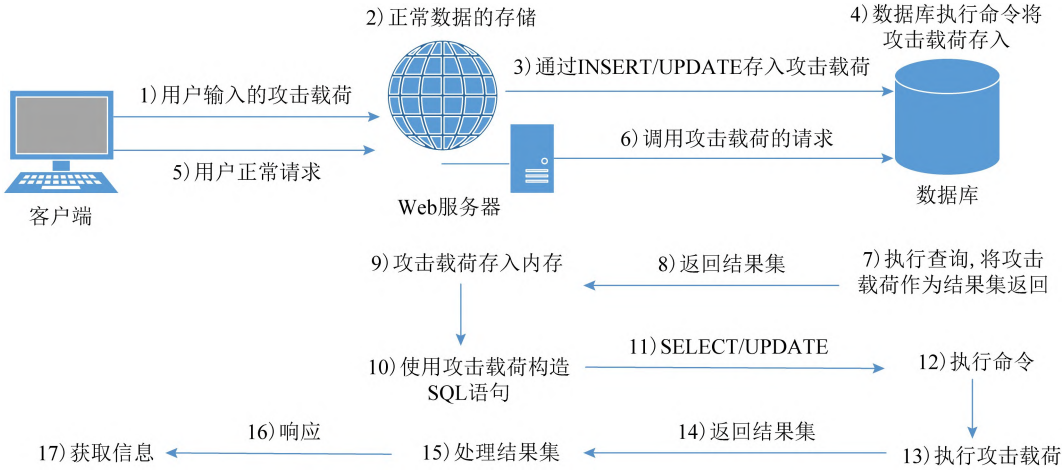

图 4　二阶 SQL 注入攻击流程

击者最常用的攻击方式.盲注的注入速度相对较慢,需要逐个字符猜解,通过给页面增加明显时延来判断注入是否生效,会导致时间延迟进一步增加.当 Web 应用对错误信息作了屏蔽处理,并且任何响应报文与注入的 SQL 语句之间不存在逻辑关联,基于时间延迟的盲注也无法产生明显时延,此时就只能选择带外通信技术,高级 SQL 注入攻击中的 SQLI+DNS 劫持混合攻击就是一个很好的选择.这种方式可以绕过防火墙的过滤检测,还能节省使用时延盲注所要消耗的大量时间.但因为此类攻击需要借助一个额外的服务器用于获取带外信道数据,所以攻击成本较高.综上所述,高级 SQL 注入攻击技术相较于传统的 SQL 注入攻击技术,技术难度高,隐蔽不易被检测,一旦被触发对系统的破坏力更大.

表 1　攻击类型

标号	攻击技术
A	重言式(tautologies)
B	堆叠查询(piggy-backed query)
C	逻辑错误查询(logically incorrect)
D	联合查询(union query)
E	存储过程(stored procedure)
F	盲注(inference)
G	编码替换(alternate encodings)
H	利用 Fast Flux 进行 SQL 注入攻击
I	利用跨域策略进行 SQL 注入攻击
J	SQLI+DDoS 混合攻击
K	SQLI+DNS 劫持混合攻击
L	SQLI+XSS 混合攻击
M	二阶 SQL 注入攻击

表 2　攻击特性分析

标号	评价指标				
	直接显示	错误推理	数据窃取	破坏可用性	绕过身份验证
A	√		√		√
B				√	√
C		√	√		
D	√	√	√		√
E	√		√		√
F		√	√		
G					
H	√		√		
I	√		√		
J				√	
K	√		√		
L	√		√		√
M		√	√	√	

注:“√”表示 SQL 注入攻击技术具有此特性.

3　SQL 注入攻击检测与防御技术研究

3.1　编码阶段防御技术

编码阶段的防御技术主要是在开发阶段对开发者的编码习惯进行约束,尽量减少注入漏洞的产生来减少攻击者利用这些漏洞进行 SQL 注入攻击的可能.

1) 输入检查.

网页在提交数据时可以通过编码设置过滤用户输入[12],严格控制用户输入数据,在一定程度上可以防御部分 SQLIA 注入攻击.但是,多数浏览器自带的查看网页源码功能可以使攻击者轻松获得网页源代码,将限制输入部分进行修改后,依然可以将非法数据提交给服务器.因此,Web 服务器也应对接收数据进行相应的验证.

2) 错误消息自定义.

Web 应用程序中的回显常会包含数据库类型、版本等敏感信息[13].通过自定义数据库返回的错误信息,减少语句执行与页面响应报文之间的逻辑关系,使注入者无法进行下一步的推理攻击.但该方法在正常用户使用系统时会降低用户体验.

3) 参数化查询.

避免使用拼接语句最好的方法就是使用参数化语句,参数化查询将 SQL 语句整体变成 1 个函数,使用占位符作为函数的变量,可以保证 SQL 语句语义的不变性,不会对攻击载荷中的关键字编码等进行解析.

4) 使用安全函数.

通过利用安全函数来过滤、转义不受信任的用户输入,可以是程序中自带的安全函数,也可以是开发时程序员自定义的安全函数.利用该方法可以提高 SQL 注入攻击的攻击难度,从而降低攻击发生的风险.

5）技术评价.

下面将对以上4种编码阶段防御技术对第2节中提到的攻击技术的防御效果进行评价，评价结果如表3所示：

表3　编码阶段的防御技术评价

防御技术	优点	缺点	传统SQL注入攻击							高级SQL注入攻击					
			A	B	C	D	E	F	G	H	I	J	K	L	M
输入检查	限制非法输入	设置易被更改	○	○	×	○	×	×	×	○	×	○	×	×	×
错误消息自定义	切断攻击者信息来源	合法用户体验差	×	×	√	×	×	√	×	×	×	×	×	×	○
参数化查询	防御最有效	易产生二阶注入	√	√	√	√	√	√	√	○	×	√	×	○	○
安全函数	对用户输入消毒	开发人员要求高，过滤不全面	○	○	○	○	○	○	×	○	×	×	×	○	×

注："√"表示能够防御对应攻击技术；"○"表示能够部分防御对应攻击技术；"×"表示不能防御对应攻击技术.

从表3可以看出编码阶段的防御技术对于传统的SQL注入攻击技术有一定的防御效果，尤其是参数化查询的防御效果最佳，能抵御几乎所有的传统的SQL注入攻击，但这些编码阶段防御技术在高级SQL注入攻击面前却显得无能为力，因为高级的SQL注入攻击技术不再是简单的字符串拼接，更多的是借助一些其他攻击技术以实现对目标系统更强的破坏能力、更短的攻击进程、更隐蔽的攻击特征.高级SQL注入攻击对新技术背景下的安全威胁检测和防御手段提出了更大挑战.

3.2　基于规则匹配的检测与防御技术

从SQL注入的攻击原理分析可知，SQL注入攻击改变了原有SQL语句的结构特征，通过创建规则集并识别检测违反规则的行为，能够有效防御已知的SQL注入攻击.匹配方法根据规则集对象的不同分为正则表达式匹配、模式匹配、语法树特征匹配以及随机化方法等.

3.2.1　正则表达式匹配方法

关键字过滤的方法具有较高的漏报、误报率，正则表达式匹配方法则提高了效率，也降低了误报率，该方法通过构建正则表达式对违背正则表达式的用户输入进行检测过滤.

Soewito等人[14]对源代码进行分析和计算，并结合使用转义字符串和正则表达式进行输入检查，防止SQL注入的发生.文献[15-16]均使用正则表达式对网络数据内容进行验证.正则表达式匹配方法实现相对容易，但检测的准确率依赖于语句的特征值，误检率高.

3.2.2　模式匹配方法

模式匹配方法原理是先归纳总结提取出所有合法SQL语句的模式，构建一个知识库或者规则集，然后利用一定的算法计算程序运行阶段用户提交的真实SQL语句与知识库和规则集中语句的距离.

Abikoye等人[17]提出一种利用Knuth-Morris-Pratt(KMP)字符串匹配算法，将用户的输入字符串与注入字符串的存储模式进行匹配，以检测任何恶意SQL注入攻击和XSS恶意代码.万卓昊等人[18]不再进行SQL语句之间的对比，而是使用N-Gram进行合法语句的特征提取和特征选择，得出具有代表性的特征向量，通过计算平均特征向量以及各语句特征向量与平均特征向量之间的距离选定阈值，根据距离是否超过阈值来判断待测语句的安全性，实验表明，当特征向量较大时使用该方法的效果最好.

3.2.3　语法树特征匹配方法

语法树特征匹配方法原理是构造SQL语句的语法树，并将待测语句的语法树与合法语法树对比判断是否为攻击语句.

石聪聪等人[19]提出一种基于语法树特征匹配的SQL注入检测模型.该模型需要在白盒情况下，通过对数据库源代码的分析提取出合法SQL语句的语法树模型，将用户输入后的拼接语句的语法树与合法语句语法树模型对比，如不匹配则会产生告警，检测准确率很高，运行时对系统性能影响小.韩宸望等人[20]在用户输入过滤中引入基于SQL语法树结构比较的方法，分别以数字型和字符型带入语句占位符中，将语句解析为2棵语法树，若其中1棵与期望中的SQL语法树结点总数不一致则判定为注入.该方法相较基于正则表达式匹配的方法具有更高拦截率、更低误报率.相较于

具体语法树[21]，抽象语法树[22-23]去除了树中冗余结点，不再展示真实语法中的所有细节，是语法树的最简描述，可以保证语法树对比过程开销更小且语法不失真.

3.2.4 SQL 指令随机化方法

将指令集随机化技术应用于 SQL 注入防御中，对 SQL 查询中的敏感字符或者关键字进行随机编码，攻击者在构造注入语句时无法预知应用程序中 SQL 语句的形式和关键字变换规则，导致注入语句的编码规则与系统内部的编码规则不一致，在解析时出错使攻击失效.

Boyd[24]基于 SQL 语句的随机化设计了 SQLRand 系统，系统为 SQL 语句中的关键字加上随机数进行变形，攻击载荷中的关键字因为未添加与系统一致的随机化后缀，在对语句进行解析还原时就会出错，从而有效阻止 SQL 注入攻击的发生.该系统采用中间代理机制不用改变已有的语法体系，还可以屏蔽数据库的错误信息保护随机标签不被泄露.

虽然 SQL 指令随机化方法在黑盒情况下能够有效抵御 SQL 注入攻击，但攻击者通过某种途径获得系统源码或通过暴力破解工具掌握随机化方法，将注入代码与随机化标签保持一致，便能注入成功.针对目前存在的问题马博林等人[25]创新性地提出基于多变执行体的 SQL 注入防御系统 SQLMVED，该系统结合拟态防御思想采用多变体执行环境，每个执行体执行期间生成互不相同的随机数进行关键字编码，用户输入语句会被代理分发到不同的执行体上进行拼接，再由对应执行体 SQL 语法解析器完成去随机化的过程，解析结果将送入表决器进行大数裁决，判断是否是注入语句.系统优势在于即使攻击者掌握了随机化方法，也只能伪造出其中一种随机化标签，非法 SQL 语句无法同时被多个解析器解析成功，经表决器裁决后可对 SQL 注入攻击及时阻断.但方法的设计需要修改网站源码，局限于使用原生 SQL 语句开发的应用程序.

3.2.5 技术评价

下面将对以上 4 种基于规则匹配的检测与防御技术进行评价，从优点、缺点以及对第 2 节中提到的攻击技术的防御和检测效果进行评价，评价结果如表 4 所示：

表 4 基于规则匹配的检测与防御技术评价

防御技术	优点	缺点	传统 SQL 注入攻击							高级 SQL 注入攻击					
			A	B	C	D	E	F	G	H	I	J	K	L	M
正则表达式匹配	归纳提取 SQL 语句特征构建知识库，匹配速度快，已知攻击检测精度高	依赖于规则的制定，规则很难全覆盖，误报率高	√	√	√	√	√	√	√	×	×	○	×	×	×
模式匹配			√	√	√	√	√	√	√	○	×	×	×	○	×
语法树特征匹配			√	√	√	√	√	√	×	×	×	×	×	○	×
SQL 指令随机化	不依赖规则集，灵活、防御性强	标签可能泄露，系统开销大	√	√	√	√	√	√	×	×	×	√	×	√	√

注："√"表示能够防御或检测对应攻击技术；"○"表示能够部分防御或检测对应攻击技术；"×"表示不能防御或检测对应攻击技术.

从表 4 的评价结果可知，基于规则匹配的检测方法都存在共同的不足，即对于规则集和知识库的过度依赖，检测结果的精确程度取决于知识库的制定是否完善.首先知识库的大小不能被很好地度量，知识库过大会增加时间空间的开销；知识库过小会使涵盖面不全、检测率降低.其次，规则的覆盖率很难达到 100%，其检测能力依赖于 SQL 语句特征提取的准确性以及知识库构建的完整性，导致这些方法无法应对现代形式多变灵活多样的新型和高级注入攻击.而 SQL 指令随机化对 SQL 查询中的敏感字符或者关键字进行随机编码，不再依赖规则集，也无需制定规则集，只要攻击者构造的攻击载荷中含有 SQL 指令就会被识别阻断，还可防御利用未知漏洞进行的 SQL 注入攻击，但如果攻击者采用编码替换方法对关键字进行编码伪装就有可能使防御失效.

3.3 基于机器学习的检测与防御技术

3.3.1 相关技术研究

虽然 SQL 注入攻击的形式多种多样，但是攻击者在进行攻击时的步骤和行为是类似的，使用

的攻击语句也存在一定的规律.因此,可以将合法和非法语句的识别转换为一个二分类问题,利用机器学习进行SQL注入攻击检测的研究已出现很多.

Kar等人[26]使用双隐马尔可夫模型预测传入的SQL语句是否为恶意的,提出一种保护Web应用程序免受SQL注入攻击的系统.Joshi等人[27]提出使用贝叶斯算法检测SQL注入攻击,结合基于角色的访问控制机制组成分类器,该方法具有简单、易实现的优点,但是检测率并不高,而且经常会有误报的情况.

特征向量的选择是模型训练中的重要一环,选择的特征向量过多或过少会导致模型过拟合或欠拟合的情况出现,对于模型最终的检测效果有很大影响.郭春等人[28]提出一种基于关键载荷截取的SQL注入检测方法SDMTKP,该方法将攻击语句区别于正常语句的部分截取出来从中提取特征,结合自然语言处理技术,采用不同分类算法进行对比实验.实验证明该方法可有效缩短分类算法的训练和检测时长,对于未包含在训练集中的攻击样本也有很好的检测能力.

当今网络流量快速膨胀,传统检测防御手段无法在实时高速网络环境兼顾SQL注入攻击检测准确和效率.针对这一问题,李铭等人[29]提出一种SQL注入行为实时在线检测的方法,在接收流量时对流量进行关键字筛选,使系统流量降低,再将可疑流量送入引入了快速傅里叶变换层的一种双层CNN复合检测网络模型中进行检测.实验证明该方法在保证检测准确率的同时很好地满足实时在线检测的效率要求.

3.3.2 技术评价

使用机器学习方法来解决SQL注入问题,检测时利用算法模型自动分析数据特征得出规律,这种自动化的方式要比人为制定的规则更全面、涵盖面更广.检测结果的准确性往往取决于特征向量的选择是否具有代表性和准确性,以及分类器的性能.特征选择的合理程度能够直接影响模型的性能,能够帮助研究者更好地理解样本的特点和底层结构,对模型和算法的改进有着非常重要的作用.不管是传统SQL注入攻击还是高级SQL注入攻击,它们之间的攻击模式、行为方式都是类似的,机器学习通过样本训练学习攻击特征,对于未知攻击也具有一定的防范能力.

3.4 高级SQL注入攻击检测与防御技术

3.4.1 相关技术研究

目前多数研究成果集中在对传统SQL注入攻击技术的防护上,而忽视了隐蔽性更强、破坏性更强的新型高级SQL注入攻击技术.本节将对针对高级SQL注入攻击技术的检测与防御技术进行介绍.

文献[30]提出了一个快速通量监控器(Fast Flux monitor, FFM),是一种实时检测Fast Flux网络的装置,基于主动和被动的混合监控方法,并使用贝叶斯分类器融合组件传感器.实验结果表明,FFM可以实时检测单通量和双通量行为,具有操作上可接受的检测概率和误报率,收集的快速通量数据库可以有效地查询,实现自动化构建.Lekies等人[31]对利用跨域策略进行的攻击的技术进行了广泛研究,设计了一种客户端防御机制DEMACRO,可以检测潜在的恶意跨域请求,并通过删除现有的会话证书来取消对它们的认证.Stampar[32]讨论了SQLMap在防御SQLI+DNS劫持混合攻击中的使用,SQLMap有许多专门为DNS防御和检测设计的指令,具有DNS Ex过滤功能,支持多种版本数据库如MsSQL,Oracle,MySQL和PostgreSQL.Kirda等人[33]设计了一款用于防御XSS攻击的个人网络防火墙Noxes.该方法只能防御一部分SQLI+XSS混合攻击,因为攻击者在进行攻击时,不仅可以使用JavaScript脚本标签还可以使用HTML标签进行攻击.文献[34]提出一种会话屏蔽技术,针对会话劫持的轻量级客户端的保护机制SessionShield,该机制可以实现用户在易受攻击的网站运营商忽略了XSS防御问题时依然实现有效保护.为有效检测二阶SQL注入攻击漏洞,李鑫等人[35]提出一种动静结合的检测方法,传统单独使用动态和静态分析都有各自的不足.动静结合的方式两者相辅相成,静态分析获取持久存储信息,动态分析获取元数据,检测结果明显优于现有技术.

3.4.2 技术评价

下面将对第2节中提到的7种高级攻击技术的防御和检测效果进行评价,评价结果如表5所示:

表 5　高级 SQL 注入攻击的检测与防御技术评价

防御技术	高级 SQL 注入攻击					
	H	I	J	K	L	M
FFM[30]	D	×	×	D	×	×
DEMACRO[31]	×	√	×	×	×	×
SQLMap[32]	×	×	D	○	D	D
Noxes[33]	×	P	×	×	○	×
SessionShield[34]	×	×	×	○	√	×
动静结合[35]	×	×	○	×	○	√

注："√"表示能够防御和检测对应攻击技术；"D"表示仅能检测对应的攻击技术；"P"表示仅能防御对应的攻击技术；"○"表示能够部分防御或检测对应攻击技术；"×"表示不能防御或检测对应攻击技术.

4　总结与展望

SQL 注入攻击从出现至今，一直都是 Web 安全和数据库安全面临的主要威胁.从本文的检测与防御技术分析可知，众多学者针对一些技术进行了更深入的研究，这些技术在检测和防御 SQL 注入攻击方面都有着不错的表现.但目前该领域仍存在一定的挑战：

1）随着科学技术的发展，SQL 注入技术也在不断翻新，多种攻击技术结合使用实现从传统攻击技术到高级攻击技术的升级，现有检测防御技术已无法有效应对.

2）如今的攻击场景是复杂的、动态的、多途径、非线性的，如何结合多种技术，提高 SQL 注入攻击语句的发现识别能力，实现更具针对性、自动化程度更高的检测技术将是未来工作的主要内容.

面对当前挑战，本文对今后的技术研究给出以下建议：

1）应采用多种检测技术相结合的方法来弥补单一检测技术涵盖面不足的问题，通过联合检测或者多次检测对结果进行决策的方法来提高检测的精度.

2）面对层出不穷的新型高级 SQL 注入攻击，需发现和选择新的可用于此类攻击的检测和防御技术，这就要求网络安全防护系统提供更全面的保护，今后的技术研发也应更重视系统的可扩展性和持续学习能力.

3）SQL 注入攻击技术虽在不断翻新，但各攻击类型之间都存在相似的行为模式或攻击特征，机器学习可以通过从攻击样本中学习攻击模式来预测待检测样本是否为攻击的一部分，对于已知攻击类型和未知攻击类型情况下都可提供帮助.

参　考　文　献

[1] Harb H M，Eleyan D，Eleyan A. SQL injection detection tools advantages and drawbacks [J]. International Journal of Wireless and Microwave Technologies，2021，11(3)：16-21

[2] OWASP. OWASP top 10 [EB/OL]. (2021-09-13) [2022-05-20]. https://owasp.org/Top10/

[3] CWE. Top25 most dangerous software error [EB/OL]. (2021-08-06) [2022-05-20]. https://cwe.mitre.org/top25/archive/2021/2021_cwe_top25.html#cwe_top_25

[4] Clarke J. SQL Injection Attacks and Defense [M]. Oxford：Elsevier Ltd，2009：21-27

[5] 黄小丹. SQL 注入漏洞检测技术综述[J]. 现代计算机，2020 (10)：51-58

[6] Shar L K，Tan H B K. Defeating SQL injection [J]. Computer，2012，46(3)：69-77

[7] Acker S V，Nikiforakis N，Desmet L，et al. FlashOver：Automated discovery of cross-site scripting vulnerabilities in rich Internet applications [C] //Proc of the 7th ACM Symp on Information，Computer and Communications Security. New York：ACM，2012：12-13

[8] Singh J P. Analysis of SQL injection detection techniques [J]. Theoretical and Applied Informatics，2016，28(1/2)：39-42

[9] Stampar M. Data retrieval over DNS in SQL injection attacks [J]. arXiv preprint，arXiv：1303.3047，2013

[10] 乐德广，李鑫，龚声蓉，等. 新型二阶 SQL 注入技术研究[J]. 通信学报，2015，36(S1)：85-93

[11] 魏友. 二阶 SQL 注入技术和检测方法研究[D]. 济南：山东大学，2018

[12] Selvamani K，Kannan A. A novel approach for prevention of SQL injection attacks using cryptography and access control policies [C] //Proc of the 2nd Int Conf on Advances in Power Electronics and Instrumentation Engineering (PEIE 2011). Berlin：Springer，2011：25-28

[13] Becher M. Web application firewalls [D]. Akademikerverlag：Universiti Teknologi MARA，2012

[14] Soewito B，Gunawan F E. Prevention structured query language injection using regular expression and escape string [J]. Procedia Computer Science，2018，135：678-687

[15] 方爽. 基于特征匹配的Web应用防火墙的研究与实现[D]. 合肥：安徽大学，2014

[16] 张卓. SQL注入攻击技术及防范措施研究[D]. 上海：上海交通大学，2007

[17] Abikoye O C，Abubakar A，Dokoro H A，et al. A novel technique to prevent SQL injection and cross-site scripting attacks using Knuth-Morris-Pratt string match algorithm [J]. EURASIP Journal on Information Security，2020，2020(1)：1-14

[18] 万卓昊，徐冬冬，梁生，等. 基于N-Gram的SQL注入检测研究[J]. 计算机科学，2019，46(7)：108-113

[19] 石聪聪，张涛，余勇. 基于语法树特征匹配的SQL注入防护方法研究与实现[C] //第2届计算智能与工业应用国际学术研讨会. 武汉：电气电子工程师协会，2011：206-210

[20] 韩宸望，林晖，黄川. 基于SQL语法树的SQL注入过滤方法研究[J]. 网络与信息安全学报，2016，2(11)：70-77

[21] 韩涛. 基于解析树的SQL注入检测方法研究[D]. 哈尔滨：哈尔滨工业大学，2013

[22] 孙伟，陈林. 基于抽象语法树的C#源代码SQL注入漏洞检测算法[J]. 信息安全研究，2015，1(2)：112-125

[23] 王杰. 基于抽象语法树的SQL注入防御研究[D]. 武汉：武汉邮电科学研究院，2018

[24] Boyd S W，Keromytis A D. SQLrand：Preventing SQL injection attacks [C] //Proc of Int Conf on Applied Cryptography and Network Security. Berlin：Springer，2004：292-302

[25] 马博林，张铮，刘浩，等. SQLMVED：基于多变体执行的SQL注入运行时防御系统[J]. 通信学报，2021，42(4)：127-138

[26] Kar D，Agarwal K，Sahoo A K，et al. Detection of SQL injection attacks using hidden Markov model [C] //Proc of IEEE Int Conf on Engineering & Technology. Piscataway，NJ：IEEE，2016：1-6

[27] Joshi A，Geetha V. SQL injection detection using machine learning [C] //Proc of 2014 Int Conf on Control，Instrumentation，Communication and Computational Technologies (ICCICCT). Piscataway，NJ：IEEE，2014：1111-1115

[28] 郭春，蔡文艳，申国伟，等. 基于关键载荷截取的SQL注入攻击检测方法[J]. 信息网络安全，2021，21(7)：43-53

[29] 李铭，邢光升，王芝辉，等. SQL注入行为实时在线智能检测技术研究[J]. 湖南大学学报：自然科学版，2020，47(8)：31-41

[30] Caglayan A，Toothaker M，Dan D，et al. Real-time Detection of Fast Flux Service Networks [M]. Piscataway，NJ：IEEE，2009：35-41

[31] Lekies S，Nikiforakis N，Tighzert W，et al. DEMACRO：Defense against malicious cross-domain requests [C] //Proc of the 15th Int Conf on Research in Attacks，Intrusions，and Defenses. Berlin：Springer，2012：254-273

[32] Bernardo D G. Sqlmap-automatic SQL injection and database take over tool [EB/OL]. (2015-03-05) [2022-07-06]. http://sqlmap.org/

[33] Kirda E，Krügel C，Vigna G，et al. Noxes：A client-side solution for mitigating cross-site scripting attacks [C] // Proc of the 2006 ACM Symp on Applied Computing (SAC). New York：ACM，2006：330-337

[34] Nikiforakis N，Meert W，Younan Y，et al. SessionShield：Lightweight protection against session hijacking [C] //Proc of Int Symp on Engineering Secure Software and Systems. Berlin：Springer，2011：87-100

[35] 李鑫，张维纬，郑力新. 动静结合的二阶SQL注入漏洞检测技术[J]. 华侨大学学报：自然科学版，2018，39(4)：600-605

王安琪

硕士研究生.主要研究方向为网络与信息安全.

anqiwang2333@163.com

杨　蓓

博士，副教授，硕士生导师.主要研究方向为人工智能、机器学习、数据挖掘.

iebyang@zzu.edu.cn

张建辉

博士，副研究员，硕士生导师.主要研究方向为网络与信息安全、网络体系架构、人工智能.

ndsczjh@163.com

王瑞民

博士，副教授，硕士生导师.主要研究方向为网络与信息安全、物联网安全.

iermwang@zzu.edu.cn